

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



THỰC TẬP TỐT NGHIỆP
BÁO CÁO THỰC TẬP TỐT NGHIỆP
KIỂM THỬ BẢO MẬT WEBSITE ĐÀO TẠO WETECH

Ngành: An toàn thông tin
Mã số: 7.48.02.02

Sinh viên thực hiện:
Trần Như Tùng – AT180648
Lớp: AT18G

Đơn vị thực tập:
Công ty cổ phần giải pháp công nghệ WETECH

Người quản lý thực tập:
TS. Vũ Thị Vân
Khoa ATTT – Học viện KTMM

Hà Nội - 2025

MỤC LỤC

MỤC LỤC.....	I
DANH MỤC KÍ HIỆU VÀ VIẾT TẮT	II
DANH MỤC HÌNH VẼ.....	III
LỜI CẢM ƠN	IV
MỞ ĐẦU.....	V
CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ CƠ SỞ THỰC TẬP.....	1
1.1. TỔNG QUAN VỀ CÔNG TY	1
1.2. KHÁI QUÁT QUÁ TRÌNH HÌNH THÀNH VÀ PHÁT TRIỂN.....	1
1.3. CƠ CẤU TỔ CHỨC VÀ NHÂN SỰ.....	3
1.3.1. Cơ cấu tổ chức	3
1.3.2. Chức năng, nhiệm vụ của từng bộ phận	3
1.4. CÁC LĨNH VỰC HOẠT ĐỘNG KINH DOANH, SẢN XUẤT	4
1.5. CHIẾN LƯỢC, ĐỊNH HƯỚNG PHÁT TRIỂN TRONG THỜI GIAN TỚI	5
KẾT LUẬN CHƯƠNG	6
CHƯƠNG 2. KIỂM THỬ BẢO MẬT WEB ĐÀO TẠO WETECH	7
2.1. MỘT SỐ HIỂM HỌA GÂY MẤT AN TOÀN ĐỐI VỚI WEBSITE PHỔ BIẾN	7
2.2. KỊCH BẢN KIỂM THỬ	7
2.2.1. Kiểm soát truy cập bị lỗi.....	7
2.2.2. Lỗi mã hóa	7
2.2.3. Lỗi chèn mã.....	8
2.2.4. Thiết kế kém an toàn.....	8
2.2.5. Lỗi xác thực	8
2.3. MÔI TRƯỜNG KIỂM THỬ.....	9
2.4. TRIỂN KHAI VÀ KẾT QUẢ KIỂM THỬ	9
2.4.1. Kiểm soát truy cập bị lỗi.....	9
2.4.2. Lỗi mã hóa	10
2.4.3. Lỗi chèn mã.....	11
2.4.4. Thiết kế kém an toàn.....	11
2.4.5. Lỗi xác thực	12
2.5. ĐÁNH GIÁ KẾT QUẢ KIỂM THỬ	13
2.6. ĐỀ XUẤT GIẢI PHÁP	14
KẾT LUẬN CHƯƠNG	15
KẾT LUẬN.....	16
TÀI LIỆU THAM KHẢO.....	17

DANH MỤC KÍ HIỆU VÀ VIẾT TẮT

Từ viết tắt	Nghĩa đầy đủ
AI	Artificial Intelligence
API	Application Programming Interface
ATTT	Information Security
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
ID	Identifier
IT	Information Technology
L&D	Learning & Development
LMS	Learning Management System
MITM	Man-in-the-Middle
OTP	One-Time Password
OWASP	Open Web Application Security Project
R&D	Research & Development
SQL	Structured Query Language
XSS	Cross-Site Scripting
ZAP	Zed Attack Proxy

DANH MỤC HÌNH VẼ

Hình 1.1. Sơ đồ cấu trúc tổ chức công ty WETECH	3
Hình 2.1. Kết quả truy cập trái phép thất bại	9
Hình 2.2. Kết quả request khi đăng nhập	10
Hình 2.3. Kết quả cookie của phiên làm việc	10
Hình 2.4. Kết quả chèn mã XSS, SQLi.....	11
Hình 2.5. Yêu cầu đổi với mật khẩu	11
Hình 2.6. Kết quả tấn công brute-force.....	12
Hình 2.7. Thành công truy cập vào phiên đăng nhập người dùng	12

LỜI CẢM ƠN

Em xin chân thành gửi lời cảm ơn đến đơn vị thực tập Witech và Cô Vũ Thị Vân – Khoa An toàn thông tin, Học viện Kỹ thuật Mật mã đã tạo điều kiện, cung cấp kiến thức chuyên sâu, trong thời gian thực hiện đề tài đã tận tình hướng dẫn, giúp đỡ, chỉ bảo. Đồng thời, em xin gửi lời cảm ơn đến các thầy cô trong Học viện Kỹ thuật mật mã đã truyền đạt cho em những kiến thức từ cơ bản đến nâng cao suốt những năm học qua, giúp em có được những kiến thức cơ bản để có thể hoàn thành được đề tài này.

Trong quá trình nghiên cứu và thực hiện đề tài, em đã nỗ lực hoàn thành với tinh thần trách nhiệm cao nhất. Tuy nhiên, do phạm vi kiến thức còn rộng và đề tài có nhiều khía cạnh phức tạp nên khó tránh khỏi những hạn chế nhất định. Em rất mong nhận được sự góp ý và chỉ dẫn từ thầy cô để có thể tiếp tục hoàn thiện và nâng cao chất lượng của đề tài.

Em xin chân thành cảm ơn!

SINH VIÊN THỰC HIỆN BÁO CÁO

Tùng

Trần Như Tùng

MỞ ĐẦU

Thực tập tốt nghiệp là giai đoạn quan trọng trong quá trình học tập, cung cấp cơ hội để rèn luyện các kỹ năng chuyên môn, tiếp cận với môi trường làm việc thực tế và học hỏi từ các chuyên gia trong ngành. Từ đó, giúp sinh viên chuẩn bị tốt hơn về mặt kinh nghiệm, kỹ năng mềm và kiến thức chuyên sâu cho công việc sau khi ra trường.

Nhận thức được vấn đề này, em đã có một tháng thực tập tại Công ty cổ phần giải pháp công nghệ Wotech, làm quen dần với cơ cấu tổ chức, môi trường làm việc của công ty và cách thức làm việc của phòng ban nơi thực tập. Từ đó giúp định hướng cho đề tài báo cáo thực tập tốt nghiệp.

Báo cáo thực tập của em với đề tài “*Kiểm thử bảo mật website đào tạo tại Wotech*” gồm:

Chương 1: Giới thiệu chung về cơ sở thực tập.

Chương 2: Kiểm thử bảo mật web đào tạo Wotech.

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ CƠ SỞ THỰC TẬP

1.1. Tổng quan về công ty



Hình 1.1: Logo công ty WETECH

Loại hình doanh nghiệp: Công ty cổ phần.

Tên công ty: Công ty cổ phần giải pháp công nghệ WETECH.

Tên quốc tế: WETECH Solution Joint Stock Company.

Mã số thuế: 0109865146.

Người đại diện: Ông Lê Minh Tuấn.

Ngày thành lập: 21/12/2021.

Điện thoại: 0914243566.

Website: witech.group.

Địa chỉ: Tầng 4, tòa nhà 791, số 27-29, ngõ 59 Láng Hạ, Ba Đình, Hà Nội.

1.2. Khái quát quá trình hình thành và phát triển

Công ty cổ phần giải pháp công nghệ WETECH được hình thành trong bối cảnh làn sóng chuyển đổi số mạnh mẽ tại Việt Nam từ cuối thập kỷ 2010, đặc biệt sau Nghị quyết 52-NQ/TW năm 2019 của Bộ Chính trị về Cách mạng công nghiệp 4.0. Các lĩnh vực như giáo dục, quản trị doanh nghiệp và công nghệ thông tin chứng kiến nhu cầu cao về giải pháp số hóa, báo cáo dữ liệu và quản lý nhân lực, tạo nền tảng cho sự ra đời của nhiều startup công nghệ, bao gồm WETECH. Ý tưởng cốt lõi của công ty xuất phát từ việc tích hợp ba yếu tố: tư duy quản trị, nghiệp vụ đào tạo (Learning & Development - L&D), và phát triển công nghệ, với đội ngũ sáng lập chủ yếu là các chuyên gia IT và L&D nhận thấy cơ hội giải quyết

vấn đề thực tế như tối ưu hóa workflow, số hóa quy trình và nâng cao năng lực con người cho doanh nghiệp và tổ chức giáo dục.

WETECH chính thức thành lập vào năm 2021, với ngày đăng ký kinh doanh là 21/12/2021 tại Sở Kế hoạch và Đầu tư Hà Nội, dưới hình thức công ty cổ phần và mã số thuế 0109865146. Đại diện pháp lý là ông Lê Minh Tuấn, trụ sở ban đầu tại Số 152 Nguyễn Huy Tưởng, Phường Thanh Xuân Trung, Quận Thanh Xuân, Thành phố Hà Nội. Vốn điều lệ ban đầu không được công bố chi tiết công khai, nhưng loại hình cổ phần cho phép huy động vốn linh hoạt từ cổ đông, phù hợp với mục tiêu mở rộng nhanh chóng. Ngành nghề chính là lập trình máy vi tính, kết hợp các hoạt động phụ như xuất bản phần mềm, tư vấn IT, quảng cáo, giáo dục đào tạo (IT, marketing, ngoại ngữ), và bán lẻ trực tuyến.

Sau thành lập, WETECH tập trung xây dựng đội ngũ và thương hiệu, từ nhóm ban đầu chuyên gia IT và L&D mở rộng quy mô nhân sự để đáp ứng nhu cầu đa dạng, nhấn mạnh văn hóa sáng tạo với đội ngũ "smart and creative people" từ nhiều nguồn gốc, cam kết hợp tác tạo giải pháp đột phá. Triết lý cốt lõi là "chủ động phối hợp – giao thoa giữa các góc nhìn sáng tạo", giúp nâng cao chất lượng sản phẩm. Công ty tăng cường hợp tác đa ngành với doanh nghiệp lớn nhỏ, trường học và đối tác quốc tế, tận dụng lợi thế Việt Nam như chi phí cạnh tranh và lực lượng lao động trẻ, nổi bật với khả năng tùy chỉnh workflow theo yêu cầu khách hàng, trở thành đối tác tin cậy trong dự án số hóa, báo cáo dữ liệu và quản trị nhân lực. Website wetech.group ra mắt để khẳng định tầm nhìn “Transforming Ideas Into Innovation”, tập trung vào cloud-based LMS và Cloud-based Analytics.

Đến năm 2025, WETECH duy trì hoạt động ổn định, mở rộng hợp tác quốc tế tận dụng xu hướng EdTech và chuyển đổi số hậu COVID-19 tại Việt Nam, nơi thị trường công nghệ giáo dục tăng trưởng mạnh nhờ đầu tư nước ngoài. Các mốc quan trọng bao gồm trở thành nhà cung cấp giải pháp cho nhiều tổ chức, tập trung minh bạch quản lý và tuân thủ pháp lý, hỗ trợ phát triển bền vững. Tổng thể, quá trình hình thành WETECH phản ánh sự thích ứng nhanh chóng với môi trường kinh doanh Việt Nam, từ startup đến đối tác đáng tin cậy trong lĩnh vực số hóa.

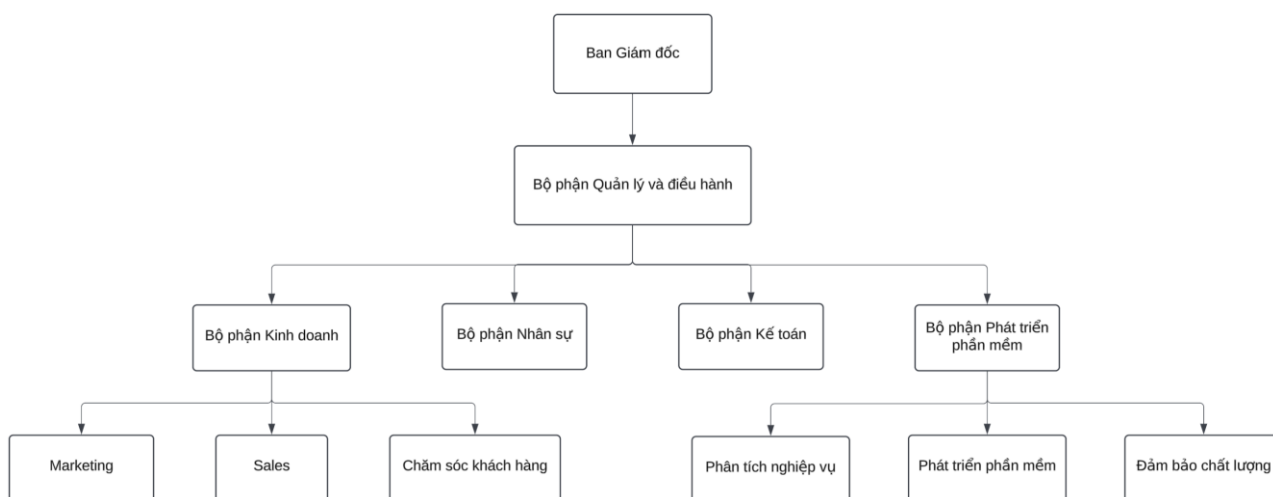
1.3. Cơ cấu tổ chức và nhân sự

1.3.1. Cơ cấu tổ chức

Đội ngũ nhân sự của công ty được tổ chức thành nhiều bộ phận chuyên trách, phù hợp với chức năng và nhiệm vụ cụ thể của từng lĩnh vực, bao gồm:

- Ban Giám đốc: 02 người
- Bộ phận Quản lý, điều hành: 04 người
- Bộ phận Nhân sự: 01 người
- Bộ phận Kinh doanh: 06 người
- Bộ phận Kế toán: 03 người
- Bộ phận Phát triển phần mềm: 20 người

Tổng số nhân viên của công ty: 36 người



Hình 1.1. Sơ đồ cấu trúc tổ chức công ty WETECH

1.3.2. Chức năng, nhiệm vụ của từng bộ phận

Để vận hành hiệu quả và đáp ứng mục tiêu phát triển, công ty được tổ chức thành các bộ phận chuyên trách, mỗi bộ phận đảm nhận một chức năng riêng nhưng luôn phối hợp chặt chẽ với nhau. Cụ thể:

- **Ban Giám đốc:** Là cấp lãnh đạo cao nhất, Ban Giám đốc giữ vai trò định hướng chiến lược và đưa ra các quyết sách quan trọng. Bộ phận này chịu trách nhiệm hoạch định mục tiêu phát triển, kiểm soát tiến độ, đồng thời giám sát hiệu quả hoạt động của toàn công ty.

- **Bộ phận Quản lý, điều hành:** Với vai trò tổ chức và điều phối, bộ phận này đảm bảo công việc giữa các phòng ban diễn ra thông suốt. Nhiệm vụ chính là phân công công việc, theo dõi tiến độ dự án và duy trì sự phối hợp nhịp nhàng nhằm đạt mục tiêu chung.

- **Bộ phận Nhân sự:** Đây là đơn vị trung tâm trong quản lý nguồn nhân lực. Bộ phận nhân sự phụ trách tuyển dụng, đào tạo, xây dựng lộ trình phát triển nghề nghiệp, đồng thời đảm bảo các chính sách phúc lợi, đãi ngộ phù hợp để cổ vũ và khích lệ nhân viên.

- **Bộ phận Kinh doanh:** Đóng vai trò phát triển thị trường và thương hiệu, bộ phận này chịu trách nhiệm nghiên cứu khách hàng, xây dựng chiến lược tiếp thị, quảng bá hình ảnh công ty. Ngoài ra, còn trực tiếp thúc đẩy doanh số và duy trì mối quan hệ bền chặt với khách hàng.

- **Bộ phận Kế toán:** Là nơi quản lý tài chính và dòng tiền của doanh nghiệp, bộ phận kế toán thực hiện hạch toán, báo cáo, đồng thời phối hợp hoạch định chi phí. Mục tiêu là đảm bảo tính minh bạch và hiệu quả trong mọi hoạt động tài chính.

- **Bộ phận Phát triển phần mềm:** Đây là lực lượng nòng cốt về công nghệ, chịu trách nhiệm xây dựng, phát triển và duy trì các hệ thống phần mềm. Bộ phận bao gồm nhóm phân tích nghiệp vụ, Back-end, Front-end, AI và kiểm thử, cùng nhau tạo ra sản phẩm ổn định, tối ưu và đáp ứng nhu cầu khách hàng.

1.4. Các lĩnh vực hoạt động kinh doanh, sản xuất

WETECH cung cấp giải pháp công nghệ đa chiều, chủ lực ở các mảng sau:

- **Giải pháp phần mềm Cloud-based:** Xây dựng nền tảng LMS, hệ thống phân tích dữ liệu và workflow quản trị trên đám mây; hỗ trợ cá nhân hóa, linh hoạt đáp ứng nhu cầu quản lý và học tập hiện đại.

- **Phân tích dữ liệu & báo cáo thông minh:** Tích hợp đa dạng nguồn dữ liệu, tạo báo cáo trực quan, hỗ trợ lãnh đạo doanh nghiệp – trường học trong việc đánh giá hiệu suất và hoạch định nguồn lực.

- **Giải pháp bảo mật – an ninh thông tin:** Tư vấn, triển khai hệ thống bảo mật toàn diện, đảm bảo an toàn dữ liệu và cam kết tuân thủ nghiêm ngặt các chuẩn mực về bảo mật thông tin.

- **Dịch vụ tư vấn & chuyển đổi số:** Tối ưu quy trình làm việc, tổ chức workflow khoa học; đồng hành cùng doanh nghiệp trong lộ trình chuyển đổi số, nâng cao năng lực cạnh tranh và phát triển nhân sự.

- **Thiết kế sáng tạo & marketing số:** Cung cấp dịch vụ thiết kế thương hiệu, truyền thông số, giúp doanh nghiệp tăng giá trị hình ảnh và tiếp cận khách hàng hiệu quả hơn.

- **Cung cấp dịch vụ phát triển năng lực nhân sự:** Tư vấn, tổ chức đào tạo, phát triển kỹ năng cho tổ chức, đặc biệt trong bối cảnh chuyển đổi công nghệ và nâng cao chất lượng nguồn lực.

1.5. Chiến lược, định hướng phát triển trong thời gian tới

Công ty cổ phần giải pháp công nghệ WETECH định hướng phát triển bền vững trong bối cảnh chuyển đổi số ngày càng sâu rộng tại Việt Nam và khu vực. Với sứ mệnh cốt lõi “Transforming Ideas Into Innovation” – biến ý tưởng thành đổi mới thực tiễn, WETECH không chỉ tập trung vào việc cung cấp các giải pháp công nghệ tiên tiến, mà còn cam kết mang đến trải nghiệm khách hàng vượt trên kỳ vọng. Triết lý phát triển của công ty đặt trọng tâm vào cộng tác sáng tạo, thiết kế workflow khoa học, phân tích dữ liệu chuyên sâu và đặc biệt là cam kết bảo mật tuyệt đối, không lưu trữ dữ liệu cá nhân nhằm xây dựng lòng tin bền vững với đối tác và khách hàng.

Trong giai đoạn 2026–2030, WETECH ưu tiên mở rộng danh mục sản phẩm cloud-based, đặc biệt là hệ thống quản lý học tập (LMS) và nền tảng phân tích dữ liệu đám mây. Song song, công ty sẽ tăng cường hợp tác với nhiều đối tác quốc tế để tận dụng lợi thế công nghệ, nâng cao khả năng mở rộng và tính linh hoạt của giải pháp. Hoạt động R&D sẽ tiếp tục được đầu tư mạnh mẽ, tập trung tích hợp các công nghệ mới như AI và machine learning, nhằm tối ưu hóa quy trình quản trị, nâng cao hiệu quả đào tạo và mang lại giá trị lâu dài cho khách hàng.

Về tổ chức, WETECH định hướng xây dựng đội ngũ nhân sự tinh gọn nhưng giàu năng lực sáng tạo. Công ty chú trọng tuyển dụng nhân sự chất lượng cao từ nhiều nguồn khác nhau, đồng thời đầu tư vào đào tạo nội bộ và phát triển văn hóa làm việc linh hoạt, cởi mở. Mục tiêu là tạo môi trường hấp dẫn để thu hút, giữ chân nhân tài, khuyến khích đổi mới sáng tạo và nâng cao hiệu suất làm việc.

Ngoài ra, WETECH tiếp tục đẩy mạnh dịch vụ khách hàng với mô hình hỗ trợ 24/7, luôn sẵn sàng tùy chỉnh giải pháp theo nhu cầu cụ thể của từng đối tác. Điều này không chỉ giúp công ty khẳng định vị thế trong lĩnh vực EdTech và quản trị số, mà còn nâng cao uy tín là một đối tác đáng tin cậy trên thị trường trong nước và quốc tế.

Tóm lại, chiến lược phát triển của WETECH hướng đến tăng trưởng ổn định, mở rộng thị trường quốc tế và đóng góp vào sự phát triển của nền kinh tế số Việt Nam. Với tinh thần linh hoạt, công ty sẵn sàng điều chỉnh kịp thời trước biến

động thị trường để bảo đảm mục tiêu dài hạn, duy trì sự minh bạch trong quản lý và tuân thủ nghiêm ngặt các quy định pháp lý.

Kết luận chương

Chương 1 đã giới thiệu tổng quan về Công ty cổ phần giải pháp công nghệ WETECH. Thông qua việc tìm hiểu quá trình hình thành và phát triển, có thể thấy WETECH được xây dựng trên nền tảng kết hợp giữa tư duy quản trị, công nghệ và đào tạo, nhanh chóng khẳng định vị thế trong lĩnh vực chuyển đổi số và giải pháp phần mềm. Cơ cấu tổ chức, nhân sự cùng chức năng, nhiệm vụ của từng bộ phận đã cho thấy sự chuyên môn hóa, phối hợp chặt chẽ nhằm đáp ứng các mục tiêu phát triển chung. Đồng thời, các lĩnh vực hoạt động kinh doanh của công ty cũng phản ánh định hướng đa dạng, linh hoạt, tập trung vào các giải pháp cloud-based, phân tích dữ liệu, bảo mật và chuyển đổi số.

Bên cạnh đó, chiến lược và định hướng trong thời gian tới thể hiện rõ tầm nhìn dài hạn của WETECH: phát triển bền vững, mở rộng hợp tác quốc tế, chú trọng R&D, ứng dụng AI – machine learning và xây dựng đội ngũ nhân sự sáng tạo, chuyên nghiệp. Đây là những yếu tố nền tảng để công ty tiếp tục khẳng định vị thế là đối tác công nghệ tin cậy tại Việt Nam và khu vực.

CHƯƠNG 2. KIỂM THỬ BẢO MẬT WEB ĐÀO TẠO WETECH

2.1. Một số hiểm họa gây mất an toàn đối với website phổ biến

Các lỗ hổng bảo mật trên website tiềm ẩn nguy cơ nghiêm trọng, có thể dẫn đến rò rỉ dữ liệu, chiếm quyền truy cập trái phép hoặc làm gián đoạn hoạt động hệ thống. Dưới đây là một số loại lỗ hổng phổ biến thường gặp:

- Kiểm soát truy cập bị lỗi: Các lỗ hổng xảy ra khi người dùng có thể truy cập vào các chức năng hoặc dữ liệu mà họ không được phép.
- Lỗi mã hóa: Lỗ hổng liên quan đến việc không bảo vệ đúng cách dữ liệu nhạy cảm như mật khẩu, số thẻ tín dụng hoặc thông tin cá nhân — thường do không mã hóa dữ liệu khi lưu trữ hoặc truyền tải, hoặc dùng cơ chế mã hóa yếu.
- Tiêm nhiễm: Xảy ra khi dữ liệu người dùng không đáng tin cậy được gửi tới trình thông dịch khiến trình thông dịch thực thi lệnh không mong muốn như SQL Injection, XSS.
- Thiết kế kém bảo mật: Vấn đề ở mức kiến trúc hay thiết kế khi thiếu các biện pháp bảo mật cần thiết, đây không phải lỗi cài đặt đơn thuần mà là sai sót trong giai đoạn thiết kế.
- Lỗi xác định và xác thực: Các vấn đề liên quan đến xác minh danh tính cho phép brute force, sử dụng credentials mặc định hoặc yếu, hoặc quản lý phiên không an toàn.

2.2. Kịch bản kiểm thử

2.2.1. Kiểm soát truy cập bị lỗi

Mục tiêu: Xác minh mọi yêu cầu kiểm tra quyền ở phía máy chủ, ngăn người dùng thường truy cập hoặc thao tác chức năng dành cho vai trò cao hơn.

Phạm vi: Đăng nhập, trang quản trị.

Các kiểm thử và kịch bản:

- Truy cập trang quản trị bằng tài khoản có quyền hạn thấp hơn → kết quả mong muốn: không cho phép truy cập, thông báo lỗi.
- Truy cập lại sau khi đăng xuất → kết quả mong muốn: thông báo không có quyền truy cập hoặc chuyển hướng đến trang đăng nhập, không hiện dữ liệu cũ.

2.2.2. Lỗi mã hóa

Mục tiêu: Đảm bảo dữ liệu nhạy cảm được mã hóa khi truyền và khi lưu sử dụng token và khóa an toàn.

Phạm vi: Đăng nhập, thêm tài khoản, đặt lại mật khẩu.

Các kiểm thử và kịch bản:

- Truy cập trang bằng HTTP → kết quả mong muốn: chuyển hướng sang HTTPS.
- Kiểm tra khi đăng nhập → kết quả mong muốn: không có mật khẩu hoặc thông tin cá nhân nhạy cảm ở dạng bản rõ.
- Kiểm tra cookie và lưu trữ trên trình duyệt → kết quả mong muốn: không lưu bí mật, cookie có cờ an toàn.

2.2.3. Lỗi chèn mã

Mục tiêu: Phát hiện các điểm nhập liệu cho phép chèn lệnh làm hệ thống thực thi ngoài ý muốn.

Phạm vi: Toàn hệ thống.

Các kiểm thử và kịch bản: Sử dụng công cụ Zap, tấn công vào các điểm đầu vào bằng kỹ thuật Fuzzer bao gồm các payload XSS, SQL Injection → Kết quả mong muốn: không có cảnh báo hoặc kiểm tra lại cảnh báo thì mã độc không thực thi thành công.

2.2.4. Thiết kế kém an toàn

Mục tiêu: Phát hiện thiếu sót trong thiết kế hoặc luồng nghiệp vụ dẫn đến kẻ tấn công có thể bị lợi dụng.

Phạm vi: Toàn hệ thống.

Các kiểm thử và kịch bản: kiểm tra hệ thống có giới hạn số lần đăng nhập sai, có yêu cầu mật khẩu mạnh, có yêu cầu xác minh email khi đăng ký không và dữ liệu nhạy cảm được bảo vệ thế nào → Kết quả mong muốn: Thiết kế đảm bảo an toàn.

2.2.5. Lỗi xác thực

Mục tiêu: Đảm bảo xác thực mạnh, chống brute-force, quản lý phiên làm việc an toàn.

Phạm vi: Đăng nhập, đặt lại mật khẩu, quản lý phiên đăng nhập.

Các kiểm thử và kịch bản:

- Thử nhiều lần đăng nhập sai → kết quả mong muốn: bị khóa tạm thời, yêu cầu captcha hoặc yêu cầu nhập mã OTP.
- Đặt mật khẩu yếu → kết quả mong muốn: hệ thống yêu cầu đặt mật khẩu mạnh hơn.

- Sao chép cookie phiên sang trình duyệt khác → kết quả mong muốn: không dùng được, có cờ an toàn.

- Đăng xuất rồi thử dùng lại cookie cũ → kết quả mong muốn: bị từ chối, không truy cập được dữ liệu.

2.3. Môi trường kiểm thử

Yêu cầu phần cứng:

- 01 máy tính.
- Cấu hình tối thiểu của: Intel Core i3 – i7, 2GB RAM, >40GB ổ cứng.

Yêu cầu phần mềm trên máy:

- Ứng dụng web đào tạo Wetech.
- Công cụ kiểm thử bảo mật Owasp Zap

Yêu cầu kết nối mạng Internet: có

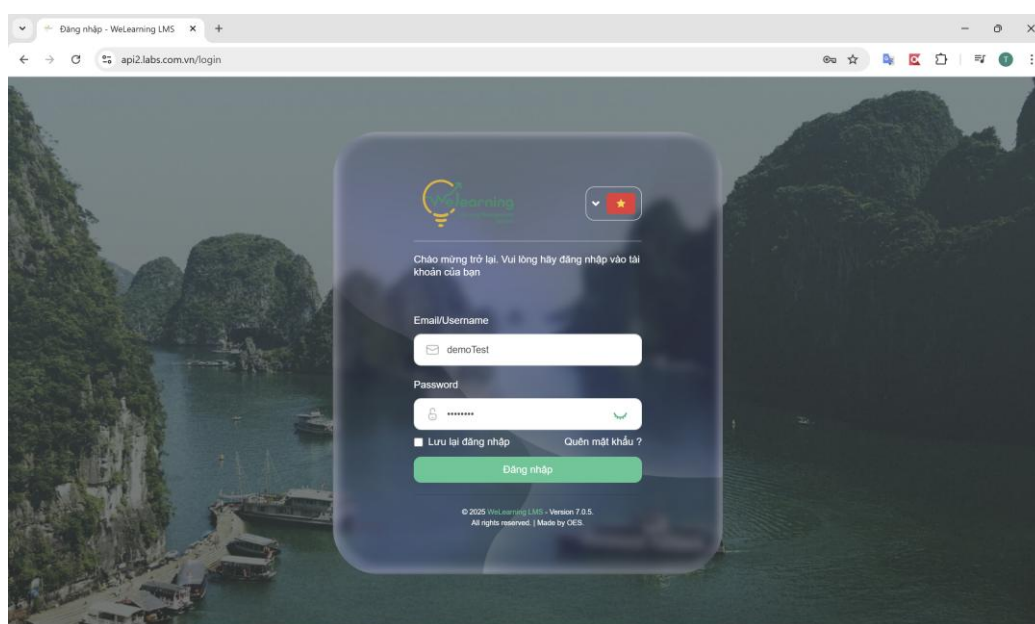
2.4. Triển khai và kết quả kiểm thử

2.4.1. Kiểm soát truy cập bị lỗi

Các bước thực hiện và kết quả:

- Đăng nhập bằng tài khoản học viên → truy cập trang quản trị người dùng bằng url `https://api2.labs.com.vn/admin/student` → kết quả: không cho phép truy cập, chuyển hướng đến trang tổng quan của học viên.

- Đăng nhập → đăng xuất → truy cập lại trang quản trị bằng URL cũ → kết quả: không cho phép truy cập, không hiển thị dữ liệu cũ.

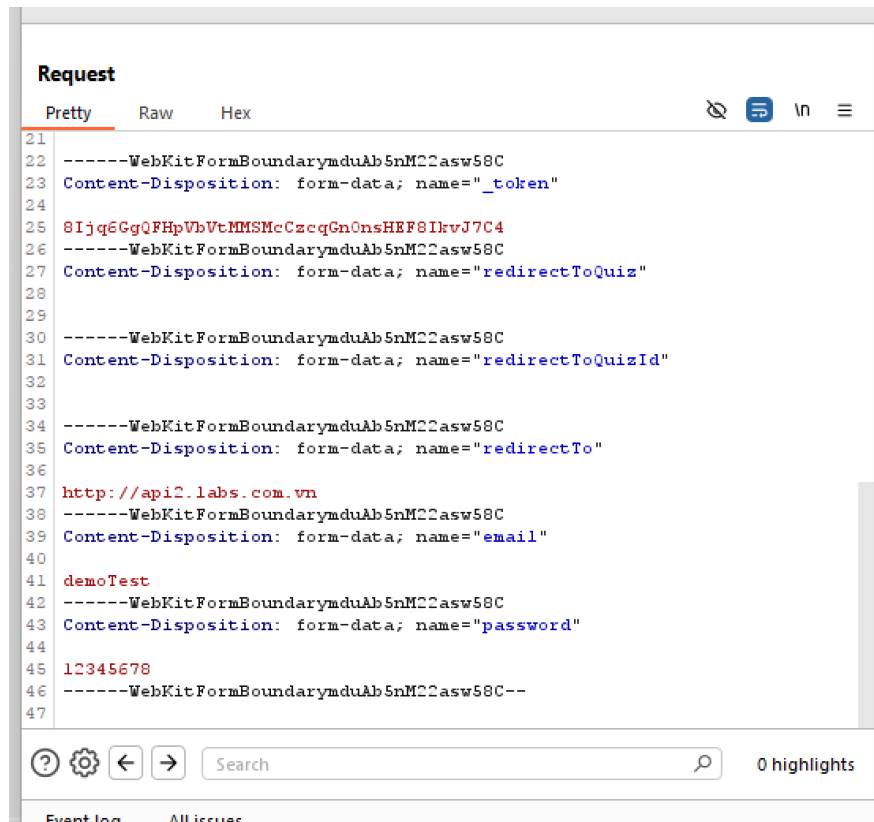


Hình 2.1. Kết quả truy cập trái phép thất bại

2.4.2. Lỗi mã hóa

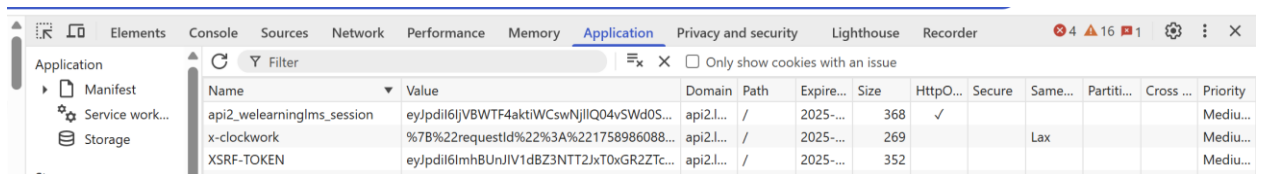
Các bước thực hiện và kết quả:

- Truy cập trang đăng nhập bằng HTTP sử dụng đường dẫn sau để đến trang đăng nhập <http://api2.labs.com.vn/login> → kết quả: tự động chuyển hướng sang `https://`.
- Kiểm tra khi đăng nhập: Thực hiện đăng nhập → kiểm tra request và response → kết quả: mật khẩu gửi đi ở dạng bản rõ.



Hình 2.2. Kết quả request khi đăng nhập

- Kiểm tra cookie và lưu trữ trên trình duyệt: Đăng nhập bằng tài khoản test → mở DevTools → kiểm tra Cookies và Storage → kết quả: không lưu bí mật trong storage, cookie có cờ HttpOnly nhưng thiếu SameSite và Secure.

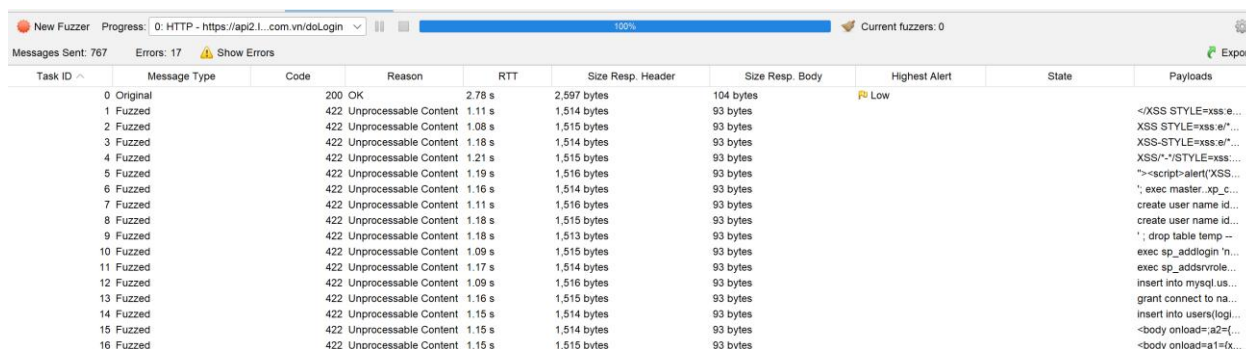


Hình 2.3. Kết quả cookie của phiên làm việc

2.4.3. Lỗi chèn mã

Các bước thực hiện và kết quả:

- Kiểm thử lỗi chèn mã: Mở công cụ Zap → nhập link web Wotech → thực hiện fuzz (payload XSS, SQLi) vào các điểm đầu vào → kiểm tra lại kết quả trả về cần xem xét.



Task ID	Message Type	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert	State	Payloads
0	Original	200	OK	2.78 s	2,597 bytes	104 bytes	Low		
1	Fuzzed	422	Unprocessable Content	1.11 s	1,514 bytes	93 bytes			<XSS STYLE=xss:e...
2	Fuzzed	422	Unprocessable Content	1.08 s	1,515 bytes	93 bytes			XSS STYLE=xss:e/...
3	Fuzzed	422	Unprocessable Content	1.18 s	1,514 bytes	93 bytes			XSS STYLE=xss:e/...
4	Fuzzed	422	Unprocessable Content	1.21 s	1,515 bytes	93 bytes			XSS STYLE=xss:e/...
5	Fuzzed	422	Unprocessable Content	1.19 s	1,516 bytes	93 bytes			><script>alert('XSS...
6	Fuzzed	422	Unprocessable Content	1.16 s	1,514 bytes	93 bytes			'; exec master..xp_c...
7	Fuzzed	422	Unprocessable Content	1.11 s	1,516 bytes	93 bytes			create user name id...
8	Fuzzed	422	Unprocessable Content	1.18 s	1,515 bytes	93 bytes			create user name id...
9	Fuzzed	422	Unprocessable Content	1.18 s	1,513 bytes	93 bytes			'; drop table temp --
10	Fuzzed	422	Unprocessable Content	1.09 s	1,515 bytes	93 bytes			exec sp_addlogin 'n...
11	Fuzzed	422	Unprocessable Content	1.17 s	1,514 bytes	93 bytes			exec sp_addservro...
12	Fuzzed	422	Unprocessable Content	1.09 s	1,516 bytes	93 bytes			insert into mytbl us...
13	Fuzzed	422	Unprocessable Content	1.16 s	1,515 bytes	93 bytes			grant connect to na...
14	Fuzzed	422	Unprocessable Content	1.15 s	1,514 bytes	93 bytes			insert into users(log...
15	Fuzzed	422	Unprocessable Content	1.15 s	1,514 bytes	93 bytes			<body onload=a2{...
16	Fuzzed	422	Unprocessable Content	1.15 s	1,515 bytes	93 bytes			<body onload=a1{x...

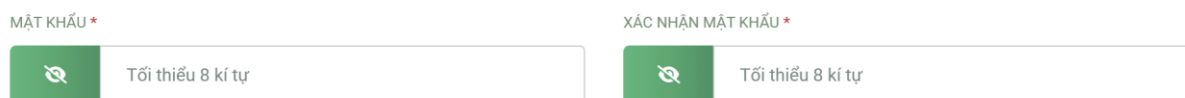
Hình 2.4. Kết quả chèn mã XSS, SQLi

- Kết quả: không có cảnh báo kiểm tra lại hay hệ thống có khả năng chặn các cuộc tấn công XSS và SQLi thông qua chèn mã vào điểm đầu vào.

2.4.4. Thiết kế kém an toàn

Các bước thực hiện và kết quả:

- Kiểm tra giới hạn đăng nhập sai: Thực hiện đăng nhập sai 5 liên tiếp → quan sát phản hồi → kết quả: hệ thống cho phép tiếp tục đăng nhập.
- Kiểm tra chính sách mật khẩu: Thử thêm tài khoản với mật khẩu yếu và mạnh → quan sát phản hồi → kết quả: cho phép thêm tài khoản với mật khẩu yếu chỉ yêu cầu tối thiểu 8 ký tự.



MẬT KHẨU *

Tối thiểu 8 kí tự

XÁC NHẬN MẬT KHẨU *

Tối thiểu 8 kí tự

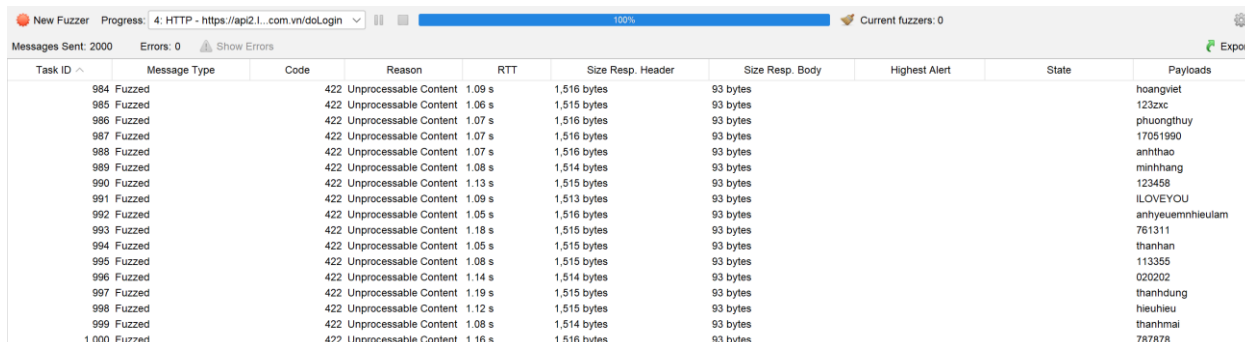
Hình 2.5. Yêu cầu đối với mật khẩu

- Kiểm tra xác minh email khi thêm tài khoản mới: Thực hiện thêm tài khoản mới → kiểm tra email có inbox và luồng xác nhận từ hệ thống không → kết quả: không nhận được email xác minh.

2.4.5. Lỗi xác thực

Các bước thực hiện và kết quả:

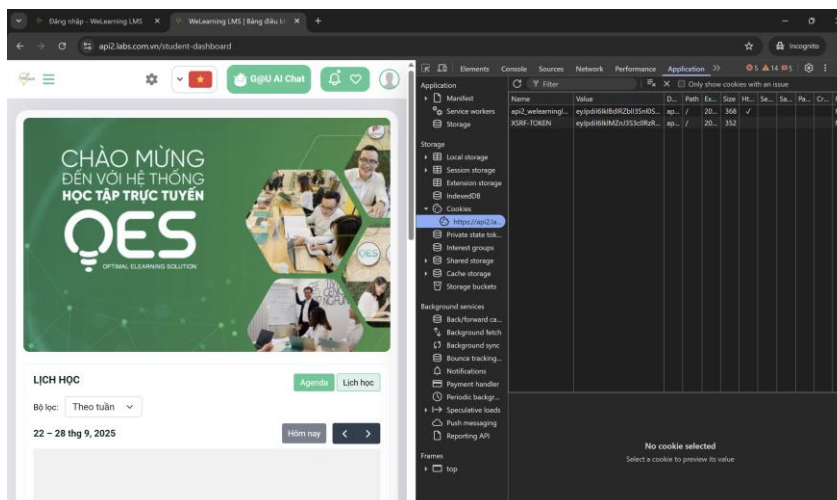
- Kiểm tra tấn công brute-force: Mở công cụ Zap → nhập link trang đăng nhập → thực hiện fuzzer string (sử dụng 1.000 mật khẩu phổ biến tại Việt Nam) vào input password → kết quả: hệ thống cho phép đăng nhập thử vô hạn, không có giới hạn số lần đăng nhập sai, không tạm khóa tài khoản người dùng.



Task ID	Message Type	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert	State	Payloads
984	Fuzzed	422	Unprocessable Content	1.09 s	1,516 bytes	93 bytes			hoangviet
985	Fuzzed	422	Unprocessable Content	1.06 s	1,515 bytes	93 bytes			123zxc
986	Fuzzed	422	Unprocessable Content	1.07 s	1,516 bytes	93 bytes			phuongthuy
987	Fuzzed	422	Unprocessable Content	1.07 s	1,516 bytes	93 bytes			17051990
988	Fuzzed	422	Unprocessable Content	1.07 s	1,516 bytes	93 bytes			anhthao
989	Fuzzed	422	Unprocessable Content	1.08 s	1,514 bytes	93 bytes			minhhang
990	Fuzzed	422	Unprocessable Content	1.13 s	1,515 bytes	93 bytes			123458
991	Fuzzed	422	Unprocessable Content	1.09 s	1,513 bytes	93 bytes			ILOVEYOU
992	Fuzzed	422	Unprocessable Content	1.05 s	1,516 bytes	93 bytes			anhyeuemnhieuam
993	Fuzzed	422	Unprocessable Content	1.18 s	1,515 bytes	93 bytes			761311
994	Fuzzed	422	Unprocessable Content	1.05 s	1,515 bytes	93 bytes			thanhan
995	Fuzzed	422	Unprocessable Content	1.08 s	1,515 bytes	93 bytes			113355
996	Fuzzed	422	Unprocessable Content	1.14 s	1,514 bytes	93 bytes			020202
997	Fuzzed	422	Unprocessable Content	1.19 s	1,515 bytes	93 bytes			thanhdung
998	Fuzzed	422	Unprocessable Content	1.12 s	1,515 bytes	93 bytes			hieuhieu
999	Fuzzed	422	Unprocessable Content	1.08 s	1,514 bytes	93 bytes			thanhai
1,000	Fuzzed	422	Unprocessable Content	1.16 s	1,516 bytes	93 bytes			787878

Hình 2.6. Kết quả tấn công brute-force

- Kiểm tra đặt mật khẩu yếu → kết quả: hệ thống cho phép (xem chi tiết các bước tại mục 2.4.4).
- Sao chép cookie phiên sang trình duyệt khác: Đăng nhập vào hệ thống → bật chế độ ẩn danh → dán cookie vào trình duyệt khác → kết quả: có thể tái sử dụng cookie, thành công truy cập vào phiên đăng nhập của người dùng.



Hình 2.7. Thành công truy cập vào phiên đăng nhập người dùng

- Kiểm tra hủy session sau logout: Đăng nhập và ghi session ID → thực hiện logout → kiểm tra Cookies → thử truy cập trang tổng quan học viên với cookie cũ → kết quả: Cookie cũ thay đổi, không truy cập được vào trang tổng quan học viên.

2.5. Đánh giá kết quả kiểm thử

Qua quá trình kiểm thử bảo mật, hệ thống được phân tích theo các tiêu chí liên quan đến kiểm soát truy cập, mã hóa, xử lý đầu vào, thiết kế hệ thống và cơ chế xác thực. Kết quả cho thấy bên cạnh một số điểm mạnh đảm bảo mức an toàn cơ bản, hệ thống vẫn tồn tại nhiều lỗ hổng tiềm ẩn có thể bị khai thác nếu không được khắc phục kịp thời, bao gồm:

- **Kiểm soát truy cập bị lỗi**

- **Điểm mạnh:** Hệ thống thực hiện tốt việc ngăn chặn truy cập trái phép. Tài khoản có quyền hạn thấp không thể truy cập hay thực hiện các chức năng yêu cầu quyền hạn cao hơn.

- **Điểm yếu:** Không có thông tin về việc hệ thống ghi lại hoặc cảnh báo các hành vi truy cập trái phép, điều này có thể khiến các nỗ lực tấn công không được phát hiện kịp thời.

- **Lỗi mã hóa**

- **Điểm mạnh:** Hệ thống tự động chuyển hướng từ HTTP sang HTTPS, đảm bảo kết nối an toàn khi truy cập trang đăng nhập.

- **Điểm yếu:** Hệ thống gửi mật khẩu dạng bản rõ trong request, dễ bị chặn bắt qua tấn công MITM. Đồng thời, cookie phiên thiếu cờ SameSite và Secure, làm tăng nguy cơ bị đánh cắp phiên qua kênh không an toàn.

- **Lỗi chèn mã**

- **Điểm mạnh:** Hệ thống có khả năng chặn và xử lý tốt các đầu vào độc hại tại thời điểm kiểm thử.

- **Điểm yếu:** Việc kiểm thử chủ yếu dựa trên công cụ tự động nên có thể chưa bao quát đầy đủ các dạng mã độc XSS, SQL injection mới.

- **Thiết kế kém an toàn**

- **Điểm yếu:** Hệ thống không giới hạn đăng nhập sai, mật khẩu yêu cầu yếu và thiếu xác minh email khi thêm tài khoản, làm tăng nguy cơ bị tấn công brute force và tài khoản giả mạo.

- **Đề xuất cải thiện:** Cần giới hạn số lần đăng nhập sai, áp dụng mật khẩu mạnh (chữ hoa, thường, số, ký tự đặc biệt) và bổ sung xác minh email khi thêm tài khoản.

- **Lỗi xác thực**

- **Điểm mạnh:** Hệ thống hủy session hợp lệ sau khi người dùng đăng xuất, đảm bảo cookie cũ không thể được tái sử dụng để truy cập trái phép.

- **Điểm yếu:** Không giới hạn đăng nhập sai, thiếu khóa tài khoản tạm thời và cho phép mật khẩu yếu. Ngoài ra, cookie phiên có thể tái sử dụng trên trình duyệt khác, làm tăng nguy cơ đánh cắp phiên.

Hệ thống hiện tại có một số điểm mạnh trong việc kiểm soát truy cập và ngăn chặn chèn mã, nhưng vẫn tồn tại nhiều lỗ hổng bảo mật nghiêm trọng, đặc biệt trong mã hóa, chính sách xác thực, và thiết kế an toàn. Các vấn đề như gửi mật khẩu bản rõ, thiếu cờ bảo mật cho cookie, không giới hạn đăng nhập sai, và không xác minh email cần được ưu tiên khắc phục để tăng cường bảo mật.

2.6. Đề xuất giải pháp

Để khắc phục những điểm yếu bảo mật đã được nhận diện và hạn chế nguy cơ bị khai thác trong thực tế, hệ thống cần bổ sung các giải pháp an toàn nhằm tăng cường khả năng chống chịu trước các mối đe dọa ngày càng phức tạp. Cụ thể, các giải pháp được đề xuất cho từng nhóm lỗ hổng như sau:

- **Kiểm soát truy cập bị lỗi**

- **Ghi nhận và cảnh báo truy cập trái phép:** Triển khai cơ chế ghi nhật ký chi tiết cho mọi nỗ lực truy cập trái phép, bao gồm thông tin IP, thời gian, và tài khoản. Cảnh báo khi có tài khoản nỗ lực truy cập trái phép.

- **Lỗi mã hóa**

- **Mã hóa mật khẩu truyền tải:** Mã hóa mật khẩu trước khi truyền tải bằng hàm băm như bcrypt phía client và đảm bảo tất cả request sử dụng HTTPS với TLS 1.3.

- **Cấu hình cookie an toàn:** Cấu hình cookie với cờ Secure chỉ gửi qua HTTPS và SameSite=Strict ngăn yêu cầu cross-site. Kiểm tra và xóa dữ liệu nhay cảm khỏi Local Storage hoặc Session Storage.

- **Thiết kế kém an toàn**

- **Giới hạn đăng nhập sai:** Khóa tài khoản tạm thời 15 phút sau 5 lần đăng nhập sai và gửi mã OTP xác minh đến email người dùng và yêu cầu nhập mã OTP sau khi mở khóa.

- **Áp dụng chính sách mật khẩu mạnh:** Yêu cầu mật khẩu tối thiểu 8 ký tự, kết hợp chữ hoa, chữ thường, số, và ký tự đặc biệt, sử dụng thư viện `zxcvbn` để đánh giá độ mạnh.

- **Xác minh email khi thêm tài khoản:** Tích hợp luồng xác minh email với liên kết xác nhận có thời hạn 24 giờ khi tạo tài khoản mới.

- Lỗi xác thực
 - **Chống tấn công brute-force và chính sách mật khẩu mạnh:** Áp dụng giới hạn đăng nhập sai và chính sách mật khẩu mạnh được trình bày chi tiết trong mục giải pháp thiết kế kém an toàn.
 - **Quản lý cookie phiên an toàn:** Liên kết cookie phiên với IP thiết bị, làm mới cookie định kỳ để giảm thời gian sống: Cookie phiên hết hạn sau 15-30 phút; refresh token hết hạn sau 24 giờ, lưu an toàn phía server. Hủy cookie cũ khi làm mới hoặc đăng xuất.

Kết luận chương

Chương 2 đã thực hiện kiểm thử bảo mật toàn diện cho ứng dụng web đào tạo Wotech, tập trung vào các lỗ hổng phổ biến như kiểm soát truy cập bị lỗi, lỗi mã hóa, lỗi chèn mã, thiết kế kém an toàn và lỗi xác thực. Quá trình kiểm thử được tiến hành với môi trường và công cụ phù hợp, có sử dụng OWASP ZAP để đánh giá các kịch bản tấn công thực tế. Kết quả kiểm thử cho thấy hệ thống có một số điểm mạnh, như ngăn chặn truy cập trái phép và xử lý tốt các cuộc tấn công chèn mã, nhưng vẫn tồn tại nhiều lỗ hổng nghiêm trọng, bao gồm gửi mật khẩu dạng bản rõ, cookie thiếu cờ bảo mật, không giới hạn đăng nhập sai, và thiếu xác minh email. Các giải pháp được đề xuất, như mã hóa dữ liệu truyền tải, áp dụng chính sách mật khẩu mạnh, quản lý cookie an toàn, và bổ sung xác minh email, nhằm khắc phục các điểm yếu và tăng cường khả năng bảo mật. Việc triển khai các giải pháp này, sẽ giúp hệ thống Wotech nâng cao khả năng chống chịu trước các mối đe dọa, đảm bảo an toàn dữ liệu và trải nghiệm người dùng.

KẾT LUẬN

Trong quá trình thực hiện báo cáo, trước hết đã thu được kết quả quan trọng là giới thiệu một cách toàn diện về Công ty cổ phần giải pháp công nghệ WETECH. Phần này đã làm rõ lịch sử hình thành, quá trình phát triển, cơ cấu tổ chức, lĩnh vực hoạt động cũng như định hướng chiến lược của công ty trong bối cảnh chuyển đổi số. Qua đó, có thể thấy WETECH là một doanh nghiệp trẻ, năng động, với nguồn nhân lực được tổ chức chặt chẽ, chuyên môn hóa cao và định hướng phát triển rõ ràng. Đây chính là cơ sở để khẳng định tiềm năng phát triển lâu dài và khả năng thích ứng với sự thay đổi nhanh chóng của công nghệ.

Song song với việc tìm hiểu cơ sở thực tập, báo cáo cũng đã tiến hành kiểm thử bảo mật đối với hệ thống web đào tạo của công ty. Các kịch bản kiểm thử được xây dựng dựa trên những nhóm lỗ hổng phổ biến theo OWASP và được thực hiện bằng một số công cụ chuyên dụng. Kết quả kiểm thử cho thấy hệ thống đã có một số điểm mạnh, chẳng hạn như khả năng ngăn chặn một số dạng tấn công chèn mã và phân quyền truy cập ở mức cơ bản. Tuy nhiên, quá trình thực nghiệm cũng đã phát hiện ra nhiều điểm yếu quan trọng, điển hình là việc mật khẩu chưa được mã hóa khi truyền tải, thiếu cơ chế giới hạn số lần đăng nhập sai, cookie phiên chưa được cấu hình an toàn và chưa có bước xác minh email khi tạo tài khoản.

Từ các phát hiện trên, báo cáo đã đưa ra những đề xuất cụ thể nhằm khắc phục và nâng cao mức độ an toàn thông tin cho hệ thống. Các giải pháp bao gồm việc áp dụng cơ chế mã hóa dữ liệu, xây dựng chính sách mật khẩu mạnh, bổ sung giới hạn số lần đăng nhập sai, cấu hình cookie phiên an toàn và tích hợp các bước xác thực bổ sung như xác minh email hoặc xác thực đa yếu tố. Đây không chỉ là những biện pháp kỹ thuật cần thiết mà còn là cơ sở để công ty nâng cao mức độ tin cậy, bảo vệ người dùng và gia tăng uy tín đối với sản phẩm, dịch vụ.

Tổng thể, các kết quả đạt được trong báo cáo đã giúp vừa làm rõ bức tranh tổng quan về WETECH, vừa phản ánh thực trạng an toàn của hệ thống web đào tạo. Điều này không chỉ hỗ trợ công ty trong việc cải tiến và hoàn thiện sản phẩm, mà còn giúp người thực hiện báo cáo rèn luyện được tư duy phân tích, kỹ năng kiểm thử và khả năng đề xuất giải pháp thực tiễn.

TÀI LIỆU THAM KHẢO

- [1] Gerardus Blokdyk. *Code Review A Complete Guide*, 5STARCook, 2021
- [2] Nguyễn Khánh Linh, *Tài liệu nội bộ công ty cổ phần giải pháp công nghệ Wotech*, Wotecg, 2023
- [3] Diego Rodrigues, *LEARN OWASP ZAP: Master Security Testing and Automated Scanning*, StudioD21 Smart Tech Content, 2025